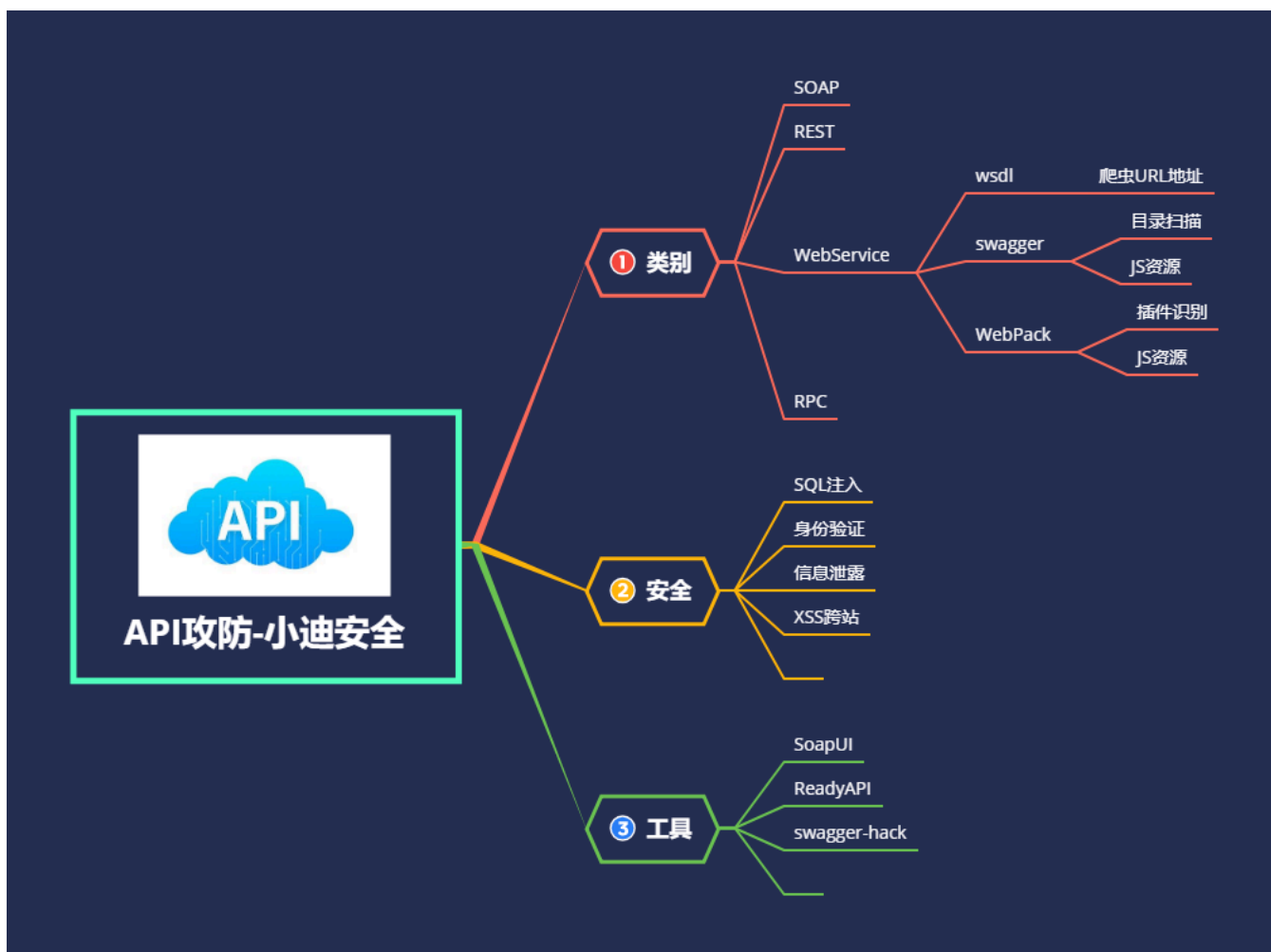


Day91 API攻防-接口安全

&SOAP&OpenAPI&RESTful&分类特征导入&项目联动检测



1.知识点

- 1、API分类特征-SOAP&OpenAPI&RESTful
- 2、API检测项目-Postman&APIKit&ReadyAPI

2.演示案例



2.1 API分类特征-SOAP&OpenAPI&RESTful



- 1 1、API分类特征
- 2 SOAP - WSDL
- 3 OpenApi - Swagger
- 4 RESTful - /v1/api/
- 5
- 6 2、API常见漏洞
- 7 OWASP API Security TOP 10 2023
- 8
- 9 3、API检测流程
- 10 接口发现，遵循分类，依赖语言，v1/v2多版本等
- 11
- 12 Method: 请求方法
- 13 攻击方式: OPTIONS, PUT, MOVE, DELETE
- 14 效果: 上传恶意文件，修改页面等

15 **URL:** 唯一资源定位符
16 攻击方式: 猜测, 遍历, 跳转
17 效果: 未授权访问等
18 **Params:** 请求参数
19 攻击方式: 构造参数, 修改参数, 遍历, 重发
20 效果: 爆破, 越权, 未授权访问, 突破业务逻辑等
21 **Authorization:** 认证方式
22 攻击方式: 身份伪造, 身份篡改
23 效果: 越权, 未授权访问等
24 **Headers:** 请求消息头
25 攻击方式: 拦截数据包, 改Hosts, 改Referer, 改Content-Type等
26 效果: 绕过身份认证, 绕过Referer验证, 绕过类型验证, DDOS等
27 **Body:** 消息体
28 攻击方式: SQL注入, XML注入, 反序列化等
29 效果: 提权, 突破业务逻辑, 未授权访问等

2.2 API检测项目-Postman&APIKit&ReadyAPI

● ● ●

1 4、API检测项目
2 工具自动化:
3 SOAP - WSDL 测试 InfoSystem
4 Postman 联动
5 SoapUI ReadyAPI
6
7 OpenApi - Swagger 测试
8 Postman 联动
9 <https://github.com/lijiejie/swagger-exp>
10 <https://github.com/jayus0821/swagger-hack>
11
12 RESTful - /v1/api/ 测试
13 Postman 联动
14 APIKit 联动
15
16 手工发包测: vapi
17 API1-身份越权
18 ID值更改遍历用户信息
19
20 API4-验证枚举
21 验证逻辑可持续提交
22
23 API5-接口枚举
24 更改URL地址尝试获取
25
26 API8-数据库注入
27
28 API9-v1/2多版本
29 V2无法爆破/V1爆破1655

```
30
31 部分项目下载:
32 https://github.com/SmartBear/soapui
33 https://github.com/API-Security/APIKit
34 https://github.com/lijiejie/swagger-exp
35 https://github.com/jayus0821/swagger-hack
36 靶场和资源总结:
37 https://github.com/roottusk/vapi
38 https://github.com/API-Security/APISandbox
39 https://github.com/arainho/awesome-api-security
```

资源:

 1 第91-1天: SOAP&Swagger&RESTful挖掘案例